

CSPM Report

Cloud Security Posture Management

CloudRuplets / Cool Delivery 2.0 · AWS eu-west-3 · Scan du 16/04/2026

Périmètre du scan	Méthodologie
3 VPC (prod, staging, dev) · 6 EC2 · 3 RDS PostgreSQL · 3 buckets S3 · IAM global · CloudTrail · VPC Flow Logs · Pipeline GitHub Actions + Terraform state (S3/DynamoDB)	Analyse statique Terraform (Checkov v3) · Secret scanning (Gitleaks) · Container CVE (Trivy) · Revue manuelle IAM et SG · Audit CloudTrail 30j

Synthèse exécutive

L'infrastructure CloudRuplets présente une posture de sécurité solide, alignée sur les bonnes pratiques AWS et les exigences RGPD. Le score global de conformité atteint **87/100**, positionnant l'environnement dans la catégorie *Mature*. L'approche Infrastructure-as-Code (Terraform) combinée aux contrôles automatisés dans la CI/CD (Checkov, Gitleaks, Trivy) garantit la reproductibilité des contrôles et réduit significativement le risque de drift. Sept findings ont été identifiés : aucun critique, 2 de sévérité moyenne et 5 faibles, tous documentés avec un plan de remédiation.

Score global de posture	Répartition des 49 contrôles évalués
87/100 050100 Posture : MATURE	Critique (0) Élevé (0) Moyen (2) Faible (5) Conforme (42)

Score par fonction NIST CSF 2.0

GOVERN (GV)		92/100	Gouvernance IaC, MFA obligatoire
IDENTIFY (ID)		85/100	Tags incomplets sur dev
PROTECT (PR)		90/100	Chiffrement KMS, segmentation
DETECT (DE)		78/100	CloudTrail OK, GuardDuty absent
RESPOND (RS)		88/100	Runbook IR, alertes SNS
RECOVER (RC)		85/100	Backups 7j, DR mono-region

Top 3 forces	Top 3 axes d'amélioration
✓ Segmentation stricte en 3 VPC isolés avec SG granulaires ✓ Chiffrement at-rest et in-transit systématique (KMS + TLS 1.3) ✓ Pas de secret en dur : SSM Parameter Store + OIDC GitHub	! Absence de GuardDuty (détection d'anomalies runtime) ! Pas de réplication cross-region des backups RDS ! Tags de gouvernance incomplets sur ressources dev

Findings détaillés

MOYEN	F-001. Absence de détection d'anomalies runtime (GuardDuty non activé)			P2
Ressource	Compte AWS global · eu-west-3	Références	CIS 4.1 (GuardDuty enabled) · NIST DE.CM-1 · RGPD Art.32.1.d	
Constat	GuardDuty n'est pas activé. L'architecture repose uniquement sur CloudTrail + VPC Flow Logs pour la détection. Aucune corrélation automatique sur les patterns d'attaque connus (crypto-mining, exfiltration, C2, recon IAM).	Remédiation	Activer GuardDuty sur eu-west-3 (environ 3€/mois en Free Tier étendu). Router les findings vers le topic SNS sécurité existant. Documenter le changement de coût dans la FinOps review.	
MOYEN	F-002. Backups RDS non répliqués cross-region			P2
Ressource	rds-prod-postgres (eu-west-3)	Références	CIS 2.3.3 (RDS backup retention) · NIST RC.RP-1 · RGPD Art.32.1.c	
Constat	La rétention RDS de 7 jours est conforme, mais les snapshots restent dans eu-west-3. En cas de sinistre régional AWS, aucun RPO garanti. Le Multi-AZ protège contre une panne d'AZ, pas contre une panne de région.	Remédiation	Activer la copie automatique des snapshots vers eu-west-1 (Irlande) via event-driven Lambda. Définir un RPO cible de 24h documenté dans le PRA.	
FAIBLE	F-003. Tags de gouvernance incomplets sur ressources dev			P3
Ressource	12 ressources dans VPC dev (10.2.0.0/16)	Références	CIS 1.21 (resource tagging) · NIST ID.AM-1 · RGPD N/A	
Constat	Les tags Environment et CostCenter sont présents, mais DataClassification et Owner manquent sur 12 ressources dev. Impact limité (pas de donnée réelle en dev) mais complique l'inventaire automatisé.	Remédiation	Ajouter une règle Checkov custom imposant les 4 tags obligatoires. Hard-fail sur la CI pour tout nouveau commit.	
FAIBLE	F-004. Rotation KMS CMK : période supérieure à 90 jours			P3
Ressource	alias/prod-key · alias/staging-key · alias/dev-key	Références	CIS 3.8 (KMS key rotation) · NIST PR.DS-1 · RGPD Art.32.1.a	
Constat	La rotation automatique des CMK est activée mais paramétrée à 365 jours. Les recommandations récentes (CIS v3) préconisent 90 jours pour les clés chiffrant des données personnelles.	Remédiation	Descendre la période de rotation à 90 jours sur prod-key. Conserver 365j sur dev/staging (pas de donnée sensible).	
FAIBLE	F-005. CloudTrail : absence de validation d'intégrité des logs			P3
Ressource	cloudtrail-main (multi-region)	Références	CIS 3.2 (CloudTrail log file validation) · NIST PR.DS-6 · RGPD Art.32.1.b	
Constat	Le trail capture bien tous les API calls, mais l'option log-file-validation n'est pas activée. Un attaquant avec accès au bucket pourrait altérer les logs sans détection.	Remédiation	Activer enable-log-file-validation=true dans la ressource Terraform aws_cloudtrail. Vérification périodique via aws cloudtrail validate-logs.	
FAIBLE	F-006. S3 : versioning activé mais MFA Delete désactivé			P3
Ressource	s3-prod-data · s3-prod-backups	Références	CIS 2.1.3 (S3 MFA Delete) · NIST PR.DS-1 · RGPD Art.32.1.c	
Constat	Le versioning protège contre la suppression accidentelle, mais sans MFA Delete, un attaquant avec credentials valides peut supprimer définitivement les versions antérieures.	Remédiation	Activer MFA Delete via AWS CLI (obligatoirement avec les credentials root, limitation AWS). Trade-off connu : complexifie la maintenance automatisée.	
FAIBLE	F-007. Security Groups : règles sortantes par défaut trop permissives			P3
Ressource	sg-app-prod · sg-app-staging	Références	CIS 5.3 (SG egress rules) · NIST PR.AC-5 · RGPD N/A	
Constat	Les SG applicatifs autorisent tout le trafic sortant (0.0.0.0/0 sur tous les ports). Une compromission de l'EC2 app faciliterait l'exfiltration.	Remédiation	Restreindre l'egress aux seuls endpoints nécessaires : HTTPS vers api.ssm.eu-west-3.amazonaws.com, S3 endpoint, RDS sur 5432. Tester en staging avant production.	

Plan de remédiation consolidé

Priorité	Findings	Délai cible	Effort estimé	Impact posture
P1	Aucun	N/A	N/A	N/A
P2	F-001, F-002	Fin du trimestre	2 j-homme	+6 points (87 → 93)
P3	F-003, F-004, F-005, F-006, F-007	Backlog sécurité	3 j-homme cumulés	+4 points (93 → 97)

Méthodologie : CIS AWS Foundations Benchmark v3.0 · NIST CSF 2.0 · RGPD Art.32. Scores calculés par Checkov et revue manuelle (IAM, réseau, chiffrement). Prochaine revue : dans 3 mois ou après changement majeur d'architecture.